

Gestão Clínica Odontológica

Guia Técnico e de Respostas para Reunião com TI da UMJ

JUNHO 2026

Breve Explicação do Sistema (O Pitch de Abertura)

O **Gestão Clínica** é uma plataforma monolítica de acompanhamento clínico e prontuário eletrônico desenvolvida sob medida para a clínica-escola de odontologia da UMJ. O objetivo principal do sistema é digitalizar a jornada do paciente (desde a anamnese até o diagnóstico e plano de tratamento) unindo agilidade acadêmica de alunos e professores à segurança jurídica e clínica. O sistema substitui fichas de papel por fluxos com assinaturas digitais, validação em tempo real e diagnósticos automatizados segundo diretrizes acadêmicas vigentes (como a classificação AAP 2018 para periodontia).

1. Ficha Técnica do Sistema (Stack de Produção)

Detalhamento dos componentes de infraestrutura e tecnologias que mantêm o sistema estável e isolado.

COMPONENTE	TECNOLOGIA	PAPEL NO SISTEMA
Linguagem	Python 3.11	Core de desenvolvimento do backend.
Framework Web	Flask 3.0.3	Roteamento, controle de requisições e sessões de usuários.
Servidor WSGI	Gunicorn + Gevent	Servidor concorrente para alta escalabilidade de conexões simultâneas.
Banco de Dados	PostgreSQL 16 (Docker)	Armazenamento relacional robusto dos dados de prontuário dos pacientes.
Fila e Cache	Redis 7 (Docker)	Broker do Celery, cache de rotas e banco do Rate Limiting.
Broker de Tarefas	Celery Worker	Processamento assíncrona da geração pesada de relatórios em PDF.
Gerador de PDF	WeasyPrint & html2pdf.js	Geração física de receitas e atestados em PDF A4 / Renderização do Períograma.
Segurança Web	Flask-WTF + Flask-Limiter	Proteção contra ataques CSRF e Rate Limit integrado ao Redis contra força bruta.
Virtualização	Docker & Docker Compose	Isolamento completo dos microsserviços do ambiente em contêineres.

2. Q&A Técnico: Dúvidas do TI por Cenários

CENÁRIO A: INFRAESTRUTURA, DEPLOY E ESCALABILIDADE

Q1. Como a aplicação é publicada e atualizada?

A aplicação é inteiramente baseada em **Docker** e orquestrada via **Docker Compose**. Temos contêineres isolados para o Web App, banco de dados Postgres, cache Redis e o Celery Worker. Atualizações e novos deploys são feitos através do build contínuo das imagens locais do Docker no servidor (`docker compose build && docker compose up -d`), o que evita conflitos de dependências do sistema operacional do host e reduz o tempo de inatividade para quase zero.

Q2. Como está estruturado o banco de dados? Vocês usam algum ORM?

Utilizamos **PostgreSQL 16** puro de forma direta via `psycopg2` e gerenciado por um pool concorrente de conexões (`ThreadedConnectionPool`) em `database.py`. Optamos por **não utilizar ORMs** (como `SQLAlchemy`) para garantir a máxima performance nas queries, controle total de índices e eliminação de gargalos tradicionais de tradução de modelo. Todas as alterações de schema gradualmente adicionadas são aplicadas defensivamente na subida do app através de uma rotina interna de migração automatizada (`_ensure_columns_exist`).

Q3. Como o sistema lida com tarefas pesadas para não travar a experiência do usuário?

Processos de processamento intenso, especificamente a geração de documentos PDF via `WeasyPrint`, foram desacoplados da thread principal da aplicação Web. Quando um aluno solicita a geração de uma receita ou atestado, a requisição é enfileirada e repassada de forma assíncrona ao **Celery Worker** usando o **Redis** como broker. O worker renderiza o documento em background e o salva em uma pasta compartilhada entre os contêineres via Docker Volume (`pdf_temp`), mantendo a navegação do usuário livre e sem latência.

CENÁRIO B: SEGURANÇA, LGPD E CONFORMIDADE LEGAL

Q4. Como os dados sensíveis dos pacientes estão protegidos?

Os dados estão isolados em uma rede virtual interna do Docker. O contêiner do banco de dados PostgreSQL está blindado e não possui suas portas expostas para a internet pública; ele é acessível exclusivamente de forma interna pelos microsserviços autorizados. O acesso à plataforma exige autenticação obrigatória via `flask_login` e as senhas dos usuários (alunos, professores, administradores) são armazenadas de forma segura utilizando criptografia de hash unidirecional de alta complexidade via `werkzeug.security` (PBKDF2).

Q5. O sistema possui alguma proteção contra ataques web comuns?

Sim. Todos os formulários da aplicação são protegidos contra ataques CSRF (Cross-Site Request Forgery) por tokens criptográficos via Flask-WTF. Além disso, implementamos proteção de taxa de requisições (Rate Limiting) via Flask-Limiter integrada ao Redis nas rotas sensíveis (como `/login`), mitigando de forma ativa ataques de força bruta ou varreduras automatizadas.

Q6. Como funcionam as assinaturas eletrônicas do sistema? Elas têm validade legal?

Sim, o sistema implementa um fluxo de conformidade legal rígido de **assinatura eletrônica simples e biometria manuscrita**. Para a evolução clínica, o sistema exige uma **Tríplice Assinatura**: (1) o Aluno Executor confirma o procedimento através de login/senha pessoal; (2) o Paciente assina na tela por meio de um elemento digital interativo (Canvas `signature_pad`), gravando a assinatura em Base64 de alta resolução; (3) o Professor Orientador valida o atendimento inserindo sua senha de duplo fator. O carimbo de data e hora (timestamp) oficial do atendimento só é gravado pelo banco de dados no exato instante em que a última assinatura é registrada.

CENÁRIO C: INTEGRIDADE DOS DADOS, BACKUPS E RECUPERAÇÃO

Q7. Se o servidor cair ou o contêiner do banco for recriado, perdemos os prontuários?

De forma alguma. Todos os dados críticos do banco de dados relacional estão montados em **volumes persistentes do Docker** (`postgres_data`). O contêiner de banco é apenas uma camada lógica de processamento; os arquivos de dados brutos residem de forma segura e permanente no armazenamento do sistema operacional do host. Mesmo que os contêineres sejam completamente removidos e recriados do zero, as informações históricas dos prontuários e pacientes permanecem intactas.

Q8. Como são feitos os backups do banco de dados?

A infraestrutura permite a geração de dumps relacionais padronizados (`pg_dump`) do PostgreSQL a qualquer momento. Esses dumps geram arquivos `.sql` compactados que podem ser programados por `crontab` no host para armazenamento em cofres de backup externos frios, garantindo tolerância a falhas físicas de hardware.

CENÁRIO D: GOVERNANÇA E CONTROLE DE ACESSO (RBAC)

Q9. Como é controlado quem pode visualizar ou alterar cada ficha?

Implementamos um controle de acesso baseado em papéis de usuário (**RBAC – Role-Based Access Control**). Os níveis de permissão são rígidos: o Administrador tem controle total; o Professor tem autoridade clínica máxima para validar tratamentos e trancar laudos; o Aluno realiza inserção operacional sob supervisão; o Atendimento (Secretaria) gerencia apenas dados cadastrais, sem acesso ao histórico clínico profundo.

Q10. O que acontece com um laudo após a validação do professor?

O laudo passa por um processo pericial de **trancamento**. Uma vez validado por um professor ou administrador através de confirmação de senha, o status de `data_validacao` é preenchido. A partir deste momento, a aplicação bloqueia qualquer requisição de alteração (POST/PUT) física daqueles dados, impedindo edições ou fraudes retroativas de histórico clínico.

3. Roteiro Sugerido para Conduzir a Reunião (30 Minutos)

Estrutura ideal sugerida para administrar o tempo curto e cobrir todos os pontos cruciais com o TI.

- ▶ **11:00h às 11:05h** **Abertura e Propósito**
Apresente o Pitch de Abertura. Explique que o sistema foi desenvolvido sob medida para digitalizar e otimizar os fluxos acadêmicos e periciais da clínica-escola de odontologia da UMJ.
- ▶ **11:05h às 11:15h** **Apresentação da Stack Técnica**
Apresente a ficha técnica. Enfatize a infraestrutura moderna baseada em contêineres Docker, o banco de dados PostgreSQL 16 para acessos concorrentes rápidos e o processador assíncrono Celery/Redis.
- ▶ **11:15h às 11:25h** **Segurança, Auditoria e LGPD**
Destaque a segurança no isolamento do banco de dados, criptografia de senhas (PBKDF2), conformidade legal com assinatura eletrônica tríplice em evolução clínica e o sistema de trancamento pericial de laudos.
- ▶ **11:25h às 11:30h** **Fechamento e Próximos Passos**
Abra espaço para dúvidas específicas que a equipe de TI da UMJ possa levantar e coloque à disposição a documentação oficial para que a equipe deles possa auditar de forma transparente.